Diplomatura en Ciberseguridad

Título:
Trabajo Práctico – Módulo 4: Ciberseguridad en la nube

Protección y cumplimiento en un escenario híbrido para historias clínicas en la nube

Estudiante:
Lucas Caminos

Profesor:
MARCELO FABIAN CUADRADO ESTREBOU

Fecha:
8 de septiembre de 2025

Introducción

En este trabajo se abordará el escenario de una organización del sector sanitario que planea migrar las historias clínicas electrónicas de sus pacientes a un esquema híbrido con servicios en la nube, accesibles vía web.
La elección de este caso responde a varias razones. Primero, porque el sector salud es uno de los más críticos en materia de ciberseguridad: un incidente no solo puede implicar la filtración de datos sensibles, sino que puede tener repercusiones directas sobre la vida y la privacidad de los pacientes.
Segundo, porque es un ejemplo ideal para aplicar de manera integral los conceptos revisados en este módulo: desde Zero Trust y defensa en profundidad hasta cifrado, gestión de identidades, normativas y cumplimiento internacional.
Finalmente, porque este caso refleja una realidad que ya ocurre: hospitales, clínicas y obras sociales están migrando cada vez más a la nube para mejorar la disponibilidad de sus servicios y responder a la demanda de acceso remoto y ágil, especialmente tras la pandemia. El desafío es hacerlo con una estrategia de seguridad adecuada, evitando caer en errores comunes como la confianza excesiva en el proveedor o la subestimación de las obligaciones regulatorias.

Desarrollo

1. Identidad como nuevo perímetro de seguridad

El primer cambio de paradigma que debe asumir la organización es que el perímetro ya no es la red física del hospital, sino las identidades digitales. El modelo tradicional, en el que bastaba con proteger con un firewall perimetral y una VPN, resulta insuficiente frente a un escenario donde médicos, administrativos e incluso pacientes acceden desde redes externas, dispositivos personales o plataformas SaaS.

Por eso, la estrategia debe partir de un sistema de gestión de identidades centralizado, como Azure Active Directory o servicios equivalentes en otras plataformas. Este enfoque permite aplicar de manera coherente los tres principios de Zero Trust:

- **Verificación explícita:** cada acceso debe autenticarse y autorizarse en función de múltiples factores, no solo de un usuario y contraseña. Aquí entra en juego la autenticación **multifactor (MFA/2FA)**, que combina algo que el usuario sabe (contraseña), algo que tiene (token, app móvil) y algo que es (biometría). Esto responde a la realidad de que las contraseñas, por sí solas, han demostrado ser insuficientes ante ataques de phishing o bases de datos filtradas.
- **Privilegios mínimos (JIT/JEA):** los usuarios deben tener acceso únicamente a lo que necesitan. Por ejemplo, un médico de guardia solo debería ver los registros de los pacientes que atiende en su turno, y no la totalidad de la base de datos. Para personal de soporte técnico, los permisos de administración deben habilitarse solo durante el tiempo estrictamente necesario, reduciendo la ventana de exposición.
- **Auditoría y trazabilidad:** cada acceso debe quedar registrado, incluyendo identidad, dispositivo, ubicación y aplicación. Esto no solo refuerza la seguridad, sino que también responde a exigencias legales como el GDPR o la HIPAA, que requieren trazabilidad para demostrar cumplimiento en caso de auditoría.

En este punto es fundamental remarcar que, aunque el proveedor de nube gestiona la infraestructura subyacente, la responsabilidad de las identidades y de la información recae siempre en la organización. Este principio de responsabilidad compartida es clave: no se puede tercerizar la obligación de definir quién accede a qué y bajo qué condiciones.

2. Zero Trust y segmentación de la infraestructura

El modelo de Confianza Cero no es simplemente una moda, sino una respuesta directa a la constatación de que los atacantes pueden eludir los controles perimetrales tradicionales. Su aplicación en este caso significa diseñar la red bajo la premisa de que todo acceso puede ser malicioso hasta que se demuestre lo contrario.
Esto se traduce en medidas concretas como la microsegmentación. En lugar de tener un gran bloque de red donde todo se comunica con todo, la infraestructura debe dividirse en segmentos aislados: servidores web, bases de datos de pacientes, sistemas administrativos, aplicaciones móviles, etc. Cada segmento solo se conecta con lo estrictamente necesario, mediante listas de control de acceso (ACL) y reglas de firewall específicas. De este modo, si un atacante compromete el servidor web público, no podrá moverse lateralmente hacia la base de datos de historias clínicas.
El principio de **"asumir la brecha"** implica aceptar que, tarde o temprano, algún control fallará. Lo importante es que el fallo no comprometa todo el sistema, sino que quede contenido en un segmento. Aquí es donde la defensa en profundidad se complementa con Zero Trust: múltiples capas (firewall, WAF, SIEM, auditorías, segmentación) que hacen más difícil avanzar a un atacante.

3. Cifrado en todos los estados de los datos

Las historias clínicas constituyen un objetivo extremadamente valioso para el cibercrimen. No solo contienen información médica, sino también datos personales y financieros. Por eso, el cifrado debe aplicarse en las tres dimensiones posibles:

- **En tránsito:** toda comunicación, ya sea entre usuarios y servidores web, o entre los distintos componentes internos, debe estar protegida por TLS 1.3 o superior. Esto impide que un atacante pueda espiar el tráfico, incluso si logra insertarse en la red.
- **En reposo:** los discos de servidores, bases de datos y respaldos deben estar cifrados con algoritmos robustos (AES-256). Un ejemplo práctico: si un atacante roba un disco físico de un servidor en el datacenter, sin las claves adecuadas, ese material resulta ilegible.
- **En uso:** tecnologías de enclaves de CPU permiten mantener cifrados los datos incluso mientras son procesados en memoria, reduciendo riesgos frente a ataques más avanzados.

Adicionalmente, para la gestión de contraseñas y credenciales, se recomienda el uso de hash con sal (salt), lo que evita ataques de diccionario o rainbow tables.
El cifrado no es solo una medida técnica, sino también un requisito de cumplimiento. Normativas como el GDPR exigen aplicar "medidas técnicas apropiadas" para garantizar la confidencialidad de los datos personales, y el cifrado es la herramienta más directa para satisfacer ese requerimiento.

4. Servicios de seguridad complementarios

El despliegue híbrido de la organización se beneficia de una serie de servicios de seguridad especializados que los proveedores cloud ofrecen como servicios administrados:

- **WAF (Web Application Firewall):** protege las aplicaciones web contra ataques como inyección SQL o cross-site scripting, amenazas incluidas en el OWASP Top 10. Dado que las historias clínicas estarán accesibles vía web, este punto es indispensable.
- **Protección DDoS:** asegura la disponibilidad del servicio ante intentos de denegación de servicio, fundamentales en un entorno donde la indisponibilidad puede afectar la atención médica.
- **Firewall cloud centralizado:** permite definir reglas uniformes para todo el tráfico entrante y saliente, evitando la dispersión de configuraciones inseguras en cada recurso.
- **Bastion:** ofrece accesos administrativos seguros (RDP/SSH) sin exponer puertos al público, reduciendo el riesgo de ataques automatizados sobre servicios de gestión.
- **SIEM/SOC:** centraliza la recolección y correlación de eventos de seguridad. Con reglas de correlación y análisis de comportamiento, se pueden detectar patrones anómalos y responder más rápido a incidentes.

La combinación de estas herramientas responde al concepto de **defensa en profundidad**, en el que se asume que ninguna medida es infalible, pero que cada capa adicional suma resiliencia.

5. Cumplimiento normativo y auditorías

La organización sanitaria no puede limitarse a pensar en la seguridad técnica: debe también demostrar cumplimiento legal. En este punto entran en juego múltiples normativas:

- **HIPAA (EE.UU.)** exige controles específicos sobre información de salud, incluyendo cifrado, auditoría y control de accesos.
- **GDPR (UE)** impone restricciones sobre la residencia de los datos y otorga derechos a los pacientes, como el acceso y rectificación de su información.
- **SOC 2 tipo II** permite verificar que los controles del proveedor cloud son efectivos en el tiempo, y no solo en un momento puntual.
- **CSA STAR** ofrece transparencia adicional sobre la madurez en seguridad de cada proveedor.

Adicionalmente, herramientas como Compliance Manager (en Azure) ayudan a monitorear en tiempo real el nivel de cumplimiento, clasificando acciones en preventivas, correctivas o de detección, y permitiendo priorizar las más críticas.
El cumplimiento normativo no debe verse como una carga burocrática, sino como una estrategia para **construir confianza** frente a pacientes, médicos, reguladores y la sociedad en general.

Conclusiones

La migración de historias clínicas a la nube representa un paso inevitable hacia la modernización del sector sanitario, pero no debe confundirse con un proceso simple de “subir datos”. Es un desafío integral que combina seguridad, cumplimiento normativo, cultura organizacional y gestión de riesgos.

La principal enseñanza es que la nube redistribuye responsabilidades, pero no las elimina. El proveedor garantiza la disponibilidad y seguridad física de la infraestructura, mientras que la organización sigue siendo responsable de la protección de datos, identidades y accesos. Este modelo de responsabilidad compartida obliga a contar con políticas claras y una gobernanza sólida.

Por otra parte, los enfoques de Zero Trust y defensa en profundidad dejan de ser meras recomendaciones teóricas: son hoy la única estrategia viable para mitigar un panorama de amenazas donde los incidentes no son una posibilidad remota, sino una certeza estadística. El objetivo no es aspirar a la seguridad absoluta, sino limitar el daño, contener al atacante y recuperar la operación rápidamente.

Sin embargo, también deben considerarse los riesgos y limitaciones: la implementación de soluciones de cifrado avanzado, microsegmentación y SIEM conlleva altos costos; la capacitación del personal médico y administrativo es tan crítica como la tecnología misma; y la dependencia de un único proveedor cloud puede convertirse en un punto de falla estratégico.

Finalmente, el cumplimiento regulatorio (HIPAA, GDPR, ISO 27017/27018, Ley 25.326 en Argentina) no debe entenderse como un obstáculo, sino como un marco que refuerza la confianza entre pacientes, profesionales y la sociedad. En un ámbito tan sensible como la salud, la confianza es tan vital como la tecnología.

En conclusión, el verdadero valor de este tipo de proyectos radica en su capacidad para integrar seguridad técnica, cumplimiento normativo y gestión organizacional en un mismo eje estratégico. No se trata solo de resguardar datos: se trata de proteger la privacidad, la seguridad y, en última instancia, la vida de los pacientes.